

Preparación, gobernanza y ciberresiliencia

Cómo organizar la seguridad antes de que ocurra un incidente

Objetivo del bloque

Comprender que la prevención no consiste únicamente en instalar controles técnicos. Una organización debe definir responsabilidades, aprobar políticas, medir su cumplimiento, gestionar excepciones e incumplimientos y comprobar mediante simulacros que sus medidas funcionan.

RA1: Desarrolla planes de prevención y concienciación en ciberseguridad, estableciendo normas y medidas de protección.

1. De la prevención a la ciberresiliencia

La prevención intenta reducir la probabilidad de que un incidente ocurra. Sin embargo, ninguna organización puede garantizar que todos los controles funcionarán siempre. Por ello, además de prevenir, debe estar preparada para resistir, continuar sus actividades, recuperarse y aprender de los problemas detectados.

Podemos resumir la ciberresiliencia en cinco capacidades:

- Anticipar: identificar riesgos, dependencias y debilidades antes de que causen daño.
- Resistir: implantar controles técnicos y organizativos que reduzcan la probabilidad y el impacto.
- Responder: saber quién debe actuar, quién decide y cómo se comunica un problema.
- Recuperarse: disponer de copias, procedimientos y prioridades para volver a la normalidad.
- Mejorar: revisar las políticas y controles tras auditorías, simulacros o incidentes.

Idea clave

Una política de seguridad debe diseñarse suponiendo que algunos controles pueden fallar. Por eso necesita responsables, mecanismos de supervisión, métricas, excepciones controladas y revisión periódica.

2. Gobernanza de la seguridad

La gobernanza establece quién toma decisiones, quién ejecuta las medidas y quién debe ser informado. Su objetivo es evitar situaciones en las que todos creen que otra persona es responsable.

Rol	Responsabilidad principal
Dirección	Aprueba la política, asigna recursos, establece prioridades y acepta determinados riesgos.
Responsable de Seguridad	Coordina la política, supervisa su cumplimiento, propone revisiones y controla excepciones.
Sistemas / IT	Implanta y mantiene controles técnicos: parches, cuentas, copias, cifrado, firewall y configuración segura.
Usuarios	Cumplen las normas, protegen sus credenciales y comunican comportamientos o incidentes sospechosos.
Proveedores	Deben cumplir los requisitos de seguridad cuando acceden a sistemas, servicios o información de la organización.
RRHH / Legal / DPO	Intervienen cuando existen cuestiones de personal, protección de datos, formación o incumplimientos.

2.1. Alcance de la política

El alcance indica a quién, a qué y dónde se aplica la política. Debe contemplar:

- Personas: empleados, directivos, becarios, personal temporal y proveedores.
- Tecnología: equipos, servidores, móviles, redes, servicios cloud y cuentas.
- Información: datos de clientes, información financiera, código fuente, correo y documentación interna.
- Ubicación: oficina, teletrabajo, viajes y accesos remotos.

3. Matriz RACI para asignar responsabilidades

La matriz RACI permite repartir responsabilidades de forma clara. Cada actividad debe indicar quién ejecuta, quién aprueba, quién debe ser consultado y quién solo necesita ser informado.

- R = Responsable: ejecuta la tarea.
- A = Accountable: aprueba o asume la responsabilidad final.
- C = Consulted: debe ser consultado antes de tomar una decisión.
- I = Informed: debe ser informado del resultado.

Actividad	Dirección	Seguridad	Sistemas	Usuarios	Proveedor
Aprobar política general	A	R	C	I	I
Revisar la política	A/I	R	C	I	C
Aplicar parches	I	C	R/A	I	C
Revisar accesos	I	A	R	I	C
Solicitar excepción	I	A	C	R/C	R/C
Comunicar incumplimiento	I	A	C	R	R

Interpretación

La matriz no significa que solo una persona participe en cada acción. Significa que las responsabilidades quedan asignadas de forma explícita y verificable.

4. Ciclo de vida de una política de seguridad

Una política no termina cuando se redacta. Debe recorrer un ciclo completo:

1. Identificar la necesidad y el contexto.
2. Analizar riesgos.
3. Redactar la política.
4. Asignar responsabilidades.
5. Aprobarla formalmente por dirección.
6. Comunicarla e implantarla.
7. Medir su cumplimiento mediante indicadores.
8. Gestionar excepciones e incumplimientos.
9. Auditar y realizar simulacros.
10. Revisarla y publicar una nueva versión cuando sea necesario.

4.1. Aprobación

La política debe quedar formalmente aprobada. El documento debería indicar, al menos, versión, fecha de aprobación, responsable, fecha de entrada en vigor y fecha de próxima revisión.

4.2. Revisión periódica

Además de una revisión programada, debe revisarse cuando se produzcan cambios relevantes como:

- nueva tecnología o servicios cloud;
- teletrabajo o BYOD;

- cambios normativos;
- incidentes graves;
- nuevos proveedores;
- auditorías con hallazgos importantes.

5. Excepciones e incumplimientos

5.1. Excepciones

Una excepción es una autorización para apartarse temporalmente de una norma cuando existe una necesidad justificada. Debe aprobarse antes de aplicar la excepción y quedar documentada.

Campo	Ejemplo
Norma afectada	Prohibición de acceso remoto no corporativo
Motivo	Mantenimiento temporal de una aplicación legacy
Solicitante	Proveedor externo
Riesgo	Acceso externo al sistema
Medidas compensatorias	VPN + MFA + registro de accesos
Responsable que autoriza	Responsable de Seguridad / Dirección
Duración	3 meses
Fecha de revisión	30/06/20XX

5.2. Incumplimientos

Un incumplimiento se produce cuando una norma no se respeta sin autorización previa. Debe registrarse, analizarse y tratarse de acuerdo con su gravedad, impacto, intencionalidad y reincidencia.

Nivel	Ejemplo	Tratamiento orientativo
Leve	Olvidar puntualmente el bloqueo de pantalla	Aviso o refuerzo formativo
Moderado	Instalar software no autorizado	Corrección + registro + revisión
Grave	Compartir credenciales	Investigación y medidas disciplinarias
Muy grave	Extraer deliberadamente información confidencial	Escalado inmediato

6. KPIs para medir el cumplimiento

Un KPI es un indicador cuantificable que permite comprobar si una política o un control está funcionando. No basta con medir: hay que comparar el resultado con un objetivo.

Cuando el indicador es porcentual, una fórmula habitual es:

$$\text{KPI} = \text{valor observado} / \text{valor total} \times 100$$

KPI	Fórmula / medida	Objetivo
Equipos actualizados	Actualizados / total × 100	≥ 95 %
MFA en cuentas privilegiadas	Cuentas con MFA / cuentas privilegiadas × 100	100 %
Usuarios formados	Formados / total × 100	≥ 95 %
Vulnerabilidades críticas corregidas	Críticas cerradas / críticas detectadas × 100	≥ 90 %
Pruebas de restauración correctas	Restauraciones correctas / pruebas × 100	100 %
Excepciones caducadas activas	Número de excepciones vencidas	0
Accesos de proveedores revisados	Revisados / total × 100	100 %

Ejemplo

Si hay 120 equipos y 108 están actualizados: $108 / 120 \times 100 = 90 \%$. Si el objetivo de la organización es $\geq 95 \%$, el control no cumple y debe generarse una acción correctiva.

7. Introducción a la continuidad

Las políticas preventivas también deben contemplar qué ocurrirá si un servicio deja de estar disponible. En esta unidad basta con conocer los conceptos básicos de continuidad.

- BCP (Business Continuity Plan): mantiene los procesos críticos del negocio durante una interrupción.
- DRP (Disaster Recovery Plan): recupera la infraestructura y los servicios TI.
- RTO (Recovery Time Objective): tiempo máximo objetivo para recuperar un servicio.
- RPO (Recovery Point Objective): cantidad máxima de datos que la organización acepta perder.

Aplicación preventiva

Si la política establece que deben existir copias de seguridad, debe definirse quién es responsable, con qué frecuencia se verifican y qué indicador demuestra que las restauraciones funcionan.

8. Simulacros para validar la política

Un simulacro permite comprobar en una situación controlada si las normas, responsabilidades y procesos son realmente aplicables. En esta unidad se utiliza como herramienta preventiva y de mejora.

Puede comprobar, por ejemplo:

- quién autoriza una excepción;
- qué ocurre cuando un proveedor solicita un acceso no previsto;
- cómo se trata un incumplimiento;
- si los contactos y responsables siguen vigentes;
- si los KPIs reflejan correctamente el cumplimiento;
- si un cambio tecnológico obliga a revisar la política.

9. Actividad de clase: Comité de Seguridad

La clase se dividirá en grupos. Cada grupo representará un Comité de Seguridad y deberá aplicar la política ante distintas situaciones.

Rol	Función en la actividad
Dirección	Aprueba la política y decide sobre riesgos relevantes.
Responsable de Seguridad	Coordina el análisis y propone decisiones.
Sistemas	Valora viabilidad técnica de controles y cambios.
Usuarios / RRHH	Representan necesidades y obligaciones del personal.
Proveedor	Plantea requisitos de terceros y accesos externos.
Auditor / Secretario	Registra decisiones y comprueba coherencia.

9.1. Inyectores del simulacro

Inyector	Situación	Decisión esperada
1	Un proveedor necesita durante tres meses una herramienta de acceso remoto prohibida por la política.	Valorar excepción, riesgo, medidas compensatorias, duración y aprobación.
2	Un empleado instala software no autorizado.	Clasificar incumplimiento, identificar responsables, corregir y registrar.
3	La empresa amplía el teletrabajo y permite BYOD.	Revisar alcance, normas y publicar una nueva versión de la política.
4	Auditoría: 92 % de equipos actualizados, 85 % de formación completada y 2 excepciones caducadas.	Interpretar KPIs, identificar incumplimientos y proponer acciones correctivas.

9.2. Entregables

- Alcance de la política.
- Matriz RACI.
- Procedimiento de aprobación.
- Procedimiento de excepciones.
- Procedimiento de incumplimientos.
- Calendario de revisión.
- Cuadro de KPIs con fórmula, fuente, responsable y objetivo.
- Acta del simulacro.
- Propuesta de mejora y nueva versión de la política si procede.

10. Resumen final

La seguridad organizativa no se limita a redactar normas. Una política eficaz debe tener alcance claro, responsables definidos, aprobación formal, métricas, control de excepciones, tratamiento de incumplimientos y mecanismos de revisión.

Secuencia de trabajo

DEFINIR → APROBAR → COMUNICAR → IMPLANTAR → MEDIR → AUDITAR → SIMULAR → CORREGIR → REVISAR

Este ciclo convierte la política de seguridad en un documento vivo y permite comprobar de forma objetiva si la organización está realmente preparada.